

PROGETTO W20D4

ALUNNO: MAZZI EMANUELE

TRACCIA:

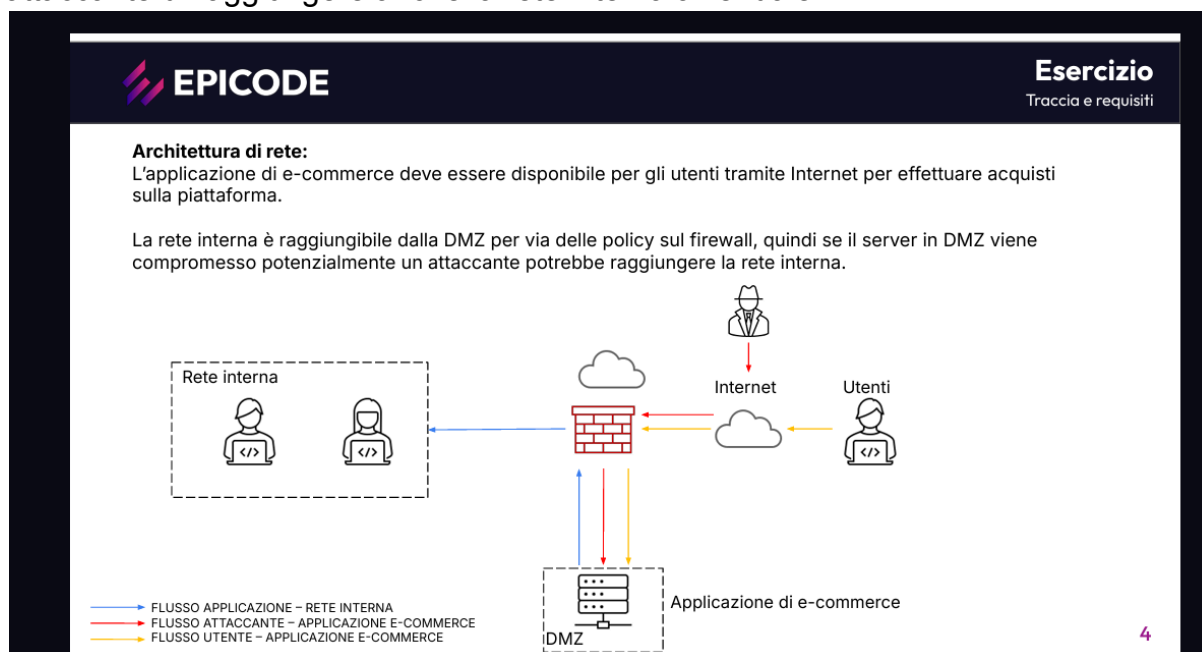
Analizzare l'infrastruttura di rete mostrata nella traccia del progetto e proporre soluzioni di sicurezza relative a prevenzione, business continuity e incident response.

L'obiettivo dell'esercizio è applicare i concetti affrontati durante il corso, tra cui:

- Security Operation
- Incident Response
- Threat Intelligence
- Vulnerability Management
- Business Continuity
- Segmentazione di rete
- Protezione delle Web Application

L'infrastruttura rappresenta una piattaforma di e-commerce pubblicata in DMZ e raggiungibile tramite Internet dagli utenti esterni.

La rete interna risulta raggiungibile dalla DMZ tramite le policy del firewall; di conseguenza, la compromissione del server Web potrebbe permettere ad un attaccante di raggiungere anche la rete interna aziendale.



1. Quali azioni preventive si potrebbero implementare per difendere l'applicazione Web da SQL Injection e XSS?

Per proteggere l'applicazione di e-commerce da attacchi di tipo SQL Injection e Cross Site Scripting (XSS), ho deciso di implementare alcune misure preventive all'interno dell'infrastruttura.

La prima soluzione introdotta è stata un Web Application Firewall (WAF) posizionato tra Internet e il server Web presente nella DMZ.

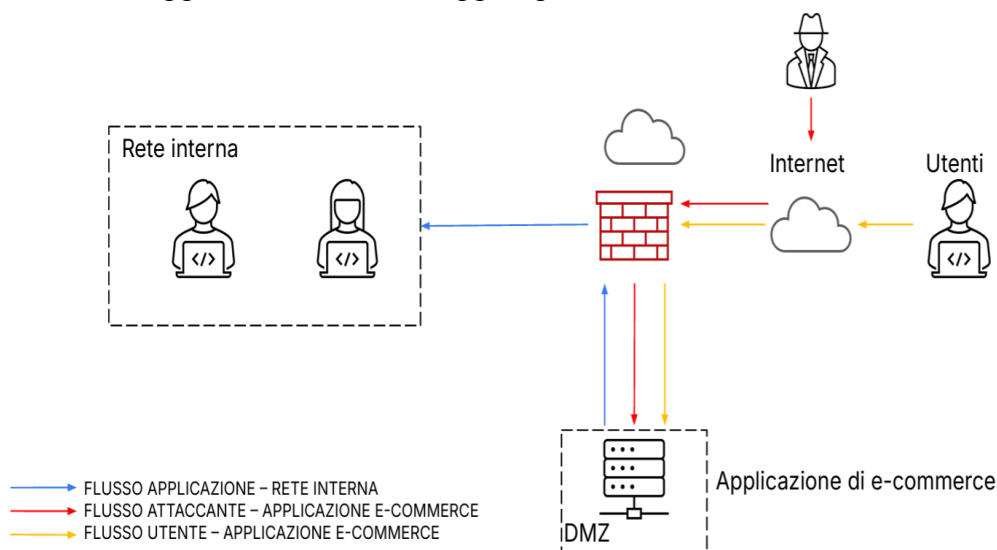
Questa soluzione permette di analizzare e filtrare le richieste HTTP dirette all'applicazione, bloccando eventuali richieste malevole associate a payload SQLi oppure script XSS.

Successivamente ho aggiunto un sistema IDS/IPS per il monitoraggio del traffico di rete e il rilevamento di attività sospette.

Questo sistema consente di identificare tentativi di scansione, exploit o traffico anomalo diretto verso il server e-commerce.

Infine ho evidenziato la necessità di limitare le comunicazioni tra DMZ e rete interna, consentendo solamente il traffico strettamente necessario.

In questo modo, anche in caso di compromissione del server Web, un attaccante avrebbe maggiori difficoltà nel raggiungere la rete interna aziendale.



2. Impatti sul business: l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che rende l'applicazione non raggiungibile per 10 minuti. Calcolare l'impatto sul business dovuto alla non raggiungibilità del servizio, considerando che in media ogni minuto gli utenti spendono 1.500 € sulla piattaforma di e-commerce. Fare eventuali valutazioni di azioni preventive che si possono applicare in questa problematica

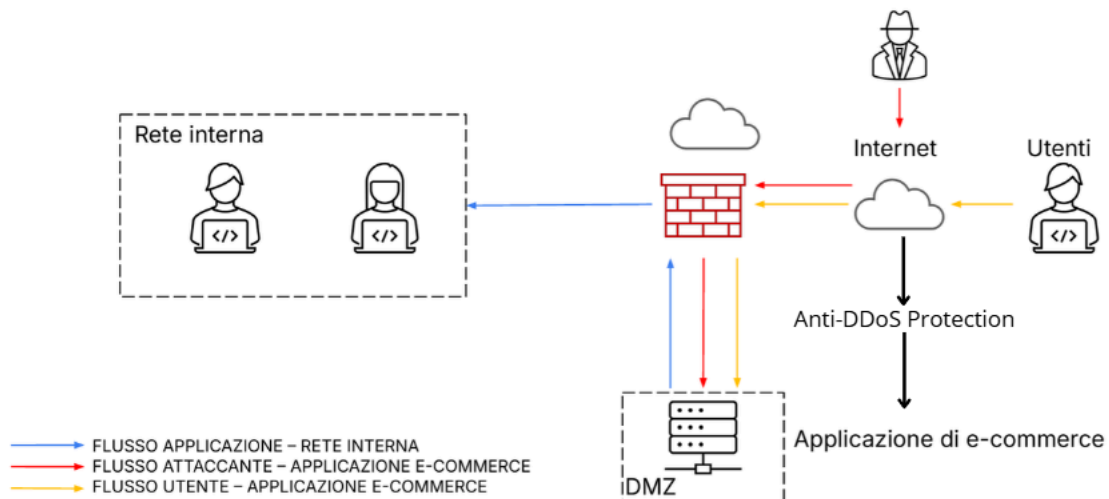
Un attacco DDoS potrebbe compromettere la disponibilità dell'applicazione e-commerce pubblicata in DMZ, impedendo agli utenti di accedere correttamente al servizio.

Considerando che mediamente gli utenti spendono circa 1.500 € al minuto sulla piattaforma, un'interruzione del servizio della durata di 10 minuti comporterebbe una perdita economica stimata pari a:

$1.500\text{€ al minuto} \times 10 \text{ minuti} = 15.000 \text{ €}$

Oltre alla perdita economica immediata, un'interruzione del servizio potrebbe causare anche danni reputazionali per l'azienda, perdita di fiducia da parte degli utenti e possibili ripercussioni sulla continuità operativa della piattaforma.

Per ridurre il rischio di questo tipo di problematica, ho considerato l'implementazione di una protezione Anti-DDoS posizionata tra Internet e l'applicazione di e-commerce. Questa soluzione permette di filtrare traffico anomalo o richieste massive dirette verso il server e-commerce, riducendo il rischio di saturazione delle risorse e migliorando la disponibilità del servizio.



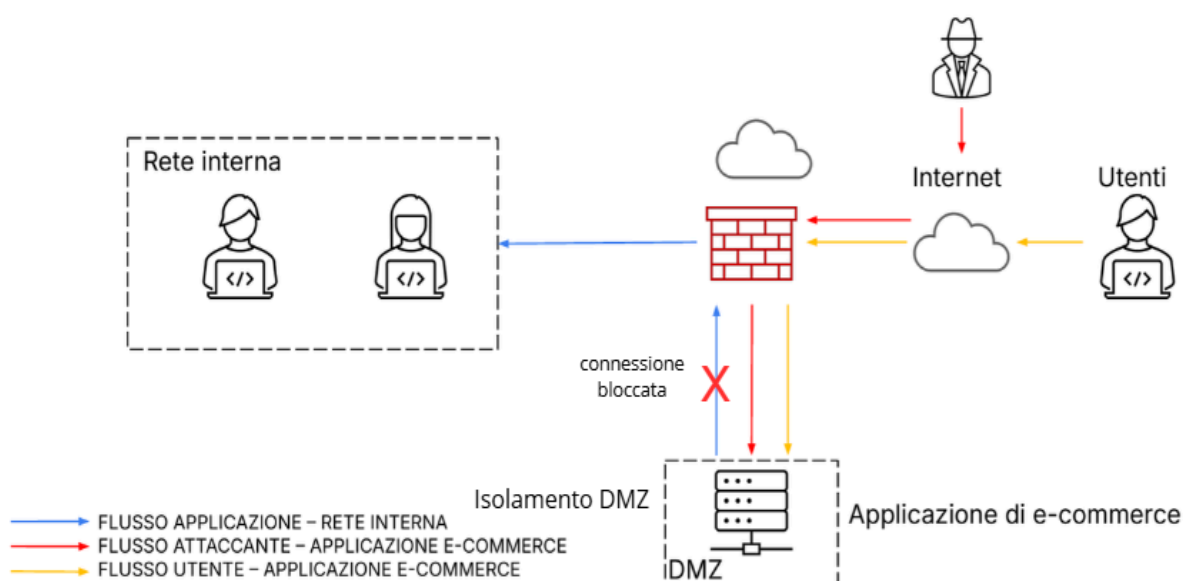
3. Response: l'applicazione Web viene infettata da un malware. La vostra priorità è che il malware non si propaghi sulla vostra rete, mentre non siete interessati a rimuovere l'accesso da parte dell'attaccante alla macchina infettata. Modificate la figura in slide 2 con la soluzione proposta.

In questo scenario ho considerato una soluzione di Incident Response basata principalmente sulla fase di containment.

Poiché la priorità non è la rimozione immediata dell'accesso dell'attaccante alla macchina compromessa, ho deciso di isolare la DMZ dalla rete interna aziendale, bloccando la comunicazione tra il server e-commerce infetto e i sistemi interni. Questa soluzione permette di ridurre il rischio di propagazione del malware verso altri sistemi presenti nella rete aziendale, limitando l'impatto dell'incidente e proteggendo gli asset interni.

L'isolamento della DMZ rappresenta quindi una misura temporanea di contenimento utile durante la gestione dell'incidente, in attesa delle successive attività di analisi e

recupero del sistema compromesso.



4. Soluzione completa: unire i disegni dell'azione preventiva e della response (unire soluzione 1 e 3)

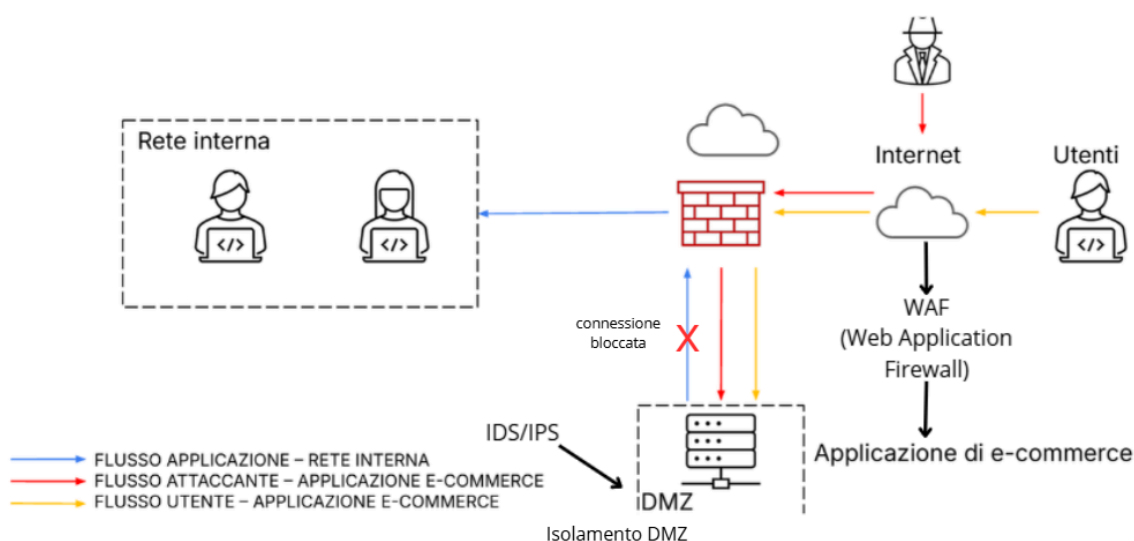
Per realizzare una soluzione più completa ho unito le misure preventive introdotte contro SQL Injection e XSS con le attività di containment utilizzate durante la gestione dell'incidente malware.

La soluzione proposta include un Web Application Firewall (WAF) per il filtraggio delle richieste HTTP malevole dirette verso l'applicazione e-commerce, oltre ad un sistema IDS/IPS per il monitoraggio del traffico e il rilevamento di attività sospette. In aggiunta, ho previsto la possibilità di isolare rapidamente la DMZ dalla rete interna aziendale in caso di compromissione del server Web.

Questa soluzione permette di limitare la propagazione del malware verso i sistemi interni, riducendo l'impatto dell'incidente sulla rete aziendale.

L'unione tra misure preventive e attività di Incident Response consente quindi di migliorare sia la protezione dell'applicazione Web sia la capacità di contenimento in

caso di attacco o compromissione del sistema.



5. Modifica «più aggressiva» dell'infrastruttura (se necessario/facoltativo magari integrando la soluzione al punto 2)

Per realizzare una soluzione di sicurezza più completa e aggressiva, ho deciso di integrare all'interno dell'infrastruttura sia le misure preventive sia le attività di contenimento e protezione della disponibilità del servizio.

La soluzione finale include un sistema Anti-DDoS per la protezione dell'applicazione e-commerce da traffico malevolo o richieste massive provenienti da Internet, riducendo il rischio di indisponibilità del servizio.

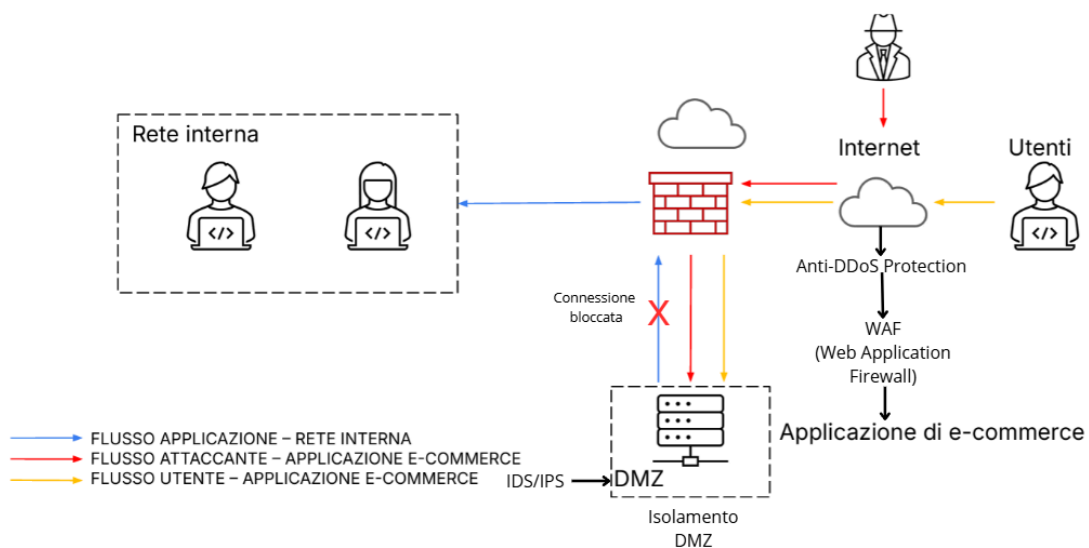
In aggiunta, ho mantenuto un Web Application Firewall (WAF) per il filtraggio delle richieste HTTP dirette all'applicazione Web e un sistema IDS/IPS per il monitoraggio del traffico di rete e il rilevamento di attività sospette.

Dal punto di vista della segmentazione, ho previsto una separazione più restrittiva tra DMZ e rete interna aziendale, consentendo solamente comunicazioni autorizzate e limitando la possibilità di propagazione laterale di eventuali malware o attaccanti.

Infine, in caso di compromissione del server e-commerce, la DMZ potrebbe essere rapidamente isolata dalla rete interna tramite attività di containment, riducendo il rischio di propagazione dell'incidente verso i sistemi aziendali interni.

Questa soluzione permette quindi di migliorare la sicurezza generale dell'infrastruttura, aumentando sia la protezione preventiva sia la capacità di risposta

agli incidenti.



CONCLUSIONI

Durante questo progetto ho analizzato l'infrastruttura proposta nella traccia applicando diversi concetti affrontati durante il corso, tra cui prevenzione degli attacchi Web, segmentazione di rete, Incident Response e Business Continuity.

Le modifiche introdotte permettono di migliorare la protezione dell'applicazione e-commerce contro attacchi esterni, limitando allo stesso tempo il rischio di propagazione di eventuali compromissioni verso la rete interna aziendale.

L'utilizzo combinato di WAF, IDS/IPS, protezione Anti-DDoS e attività di containment consente di aumentare sia la sicurezza preventiva sia la capacità di risposta agli incidenti.